

Lab07 - Physical Security

Introduction

In this week's lab we will focus on the implications of physical security, a much overlooked aspect of computer and networking security. You will be using your Ubuntu Desktop and Windows10 machines for this lab.

Physical Security

The physical security of a system (both an individual computer and the supporting infrastructure) is just as important as the security mechanisms employed to monitor and secure the information they convey. Up to this point we've been focused on the security aspects of protocols and general management practices. It is important to note that no form of authentication can repair a cut wire or a stolen hard drive. Unless absolutely necessary, it is generally not a good practice to allow users physical access to a critical system.

Once someone has physical access, it is easy to employ any of the methods or devices listed below:

- + Keyloggers
- + Rogue USB devices ([Rubber Duckies](#))
- + Stealing/cloning entire hard drives
- + Ethernet Wiretaps
- + Rogue access points
- + Rootkit installation
- + Booting via live image/single user mode

We will attempt to access both Linux and Windows systems Administrator/root accounts by taking advantage of physical access to a machine. Seeing as we are working in a virtual environment, physical access is equivalent to having the ability to mount arbitrary disk images (ISOs) and edit boot parameters.

Live Images

A live image is a fully contained (although typically minimal) operating system that is able to be booted from a read-only storage device. These devices can either be USB drives or CD/DVD disks, which allow for convenient carrying and concealment. The benefit to having a live image handy is that it essentially provides a user with a self-defined linux system that runs on top of the existing hardware - the underlying system simply becomes a collection of files and directories on the internal hard drive.

Right now, it is important to understand the difference between defining security policies and enforcing the policies. A good example of this is the system of permissions used by linux systems. In linux, users are able to specify Access Control Lists (ACLs) individually on a per-object basis. This is metadata that is stored within the underlying filesystem and defines what a specific user is able or not able to do to a particular object. These are the bits shown in a long directory listing (`rw-rw-r-x alex users bar.foo` in the image below) and specify read/write/execute permissions for each owner/group/world per each individual file.

```
[alex@Monarch test]$ ls -la
total 8
drwxr-xr-x  2 alex users 4096 Mar  5 12:49 .
drwx--x---+ 50 alex users 4096 Mar  5 12:49 ..
-rw-rw-r-x  1 alex users   0 Mar  5 12:49 bar.foo
-rw-rw-r-x  1 root users   0 Mar  5 12:49 foo.bar
-rw-rw-r-x  1 alex users   0 Mar  5 12:49 that
-rwSrSr-x  1 root root    0 Mar  5 12:49 this
[alex@Monarch test]$
```

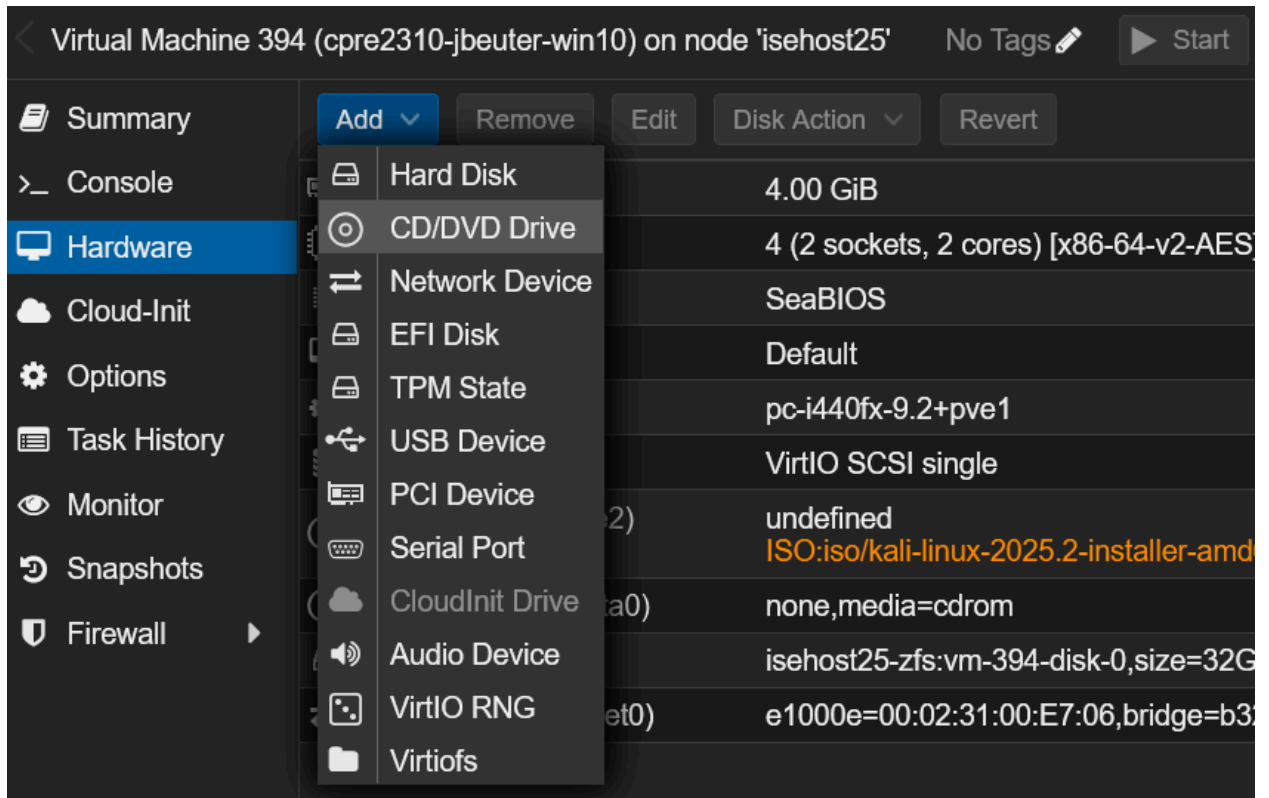
It should be noted that the file system only specifies the security policy - it does nothing about the actual enforcement of the security definitions. The interpreter (in this case the operating system - Ubuntu) is responsible for reading these definitions and enforcing them as users attempt to perform certain actions. It is this relationship between the filesystem and the operating system that ensure that users are restricted to their associated clearances.

This is why the idea of an independent operating system that is able to be carried around in one's pocket on a USB stick or DVD should strike fear into the heart of every systems administrator. By booting into a live linux image where a user has full root access (common among liveboot disks), the user could then mount the targeted filesystem and browse to his/her heart's content because the live image is allowing him/her to view the file system through the lens of a root user. Livebooting is typically prevented by locking down the boot menu and BIOS settings via an administrative password, however, is not a default configuration and must be manually done on each individual machine.

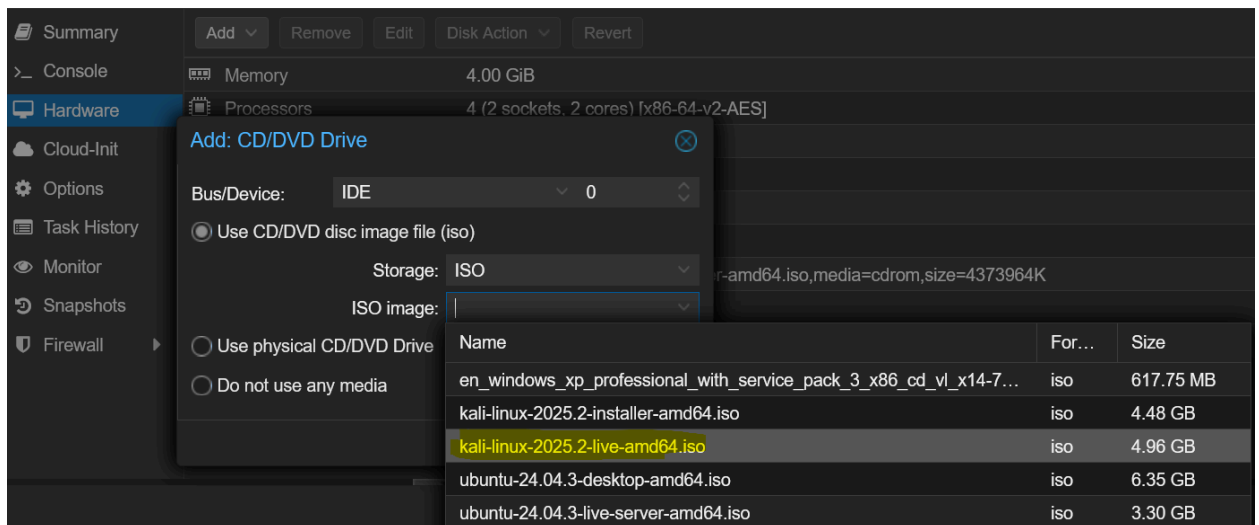
We will use a live Kali image to mount the filesystem of our Windows10 machine (`cpre2310_[netid]_win10`) and with the help of the root account and the `chntpw` utility, remove the password for the Windows Administrative user "yellowsnow". This is just the vanilla ISO image that is used for standard Kali installation - no modifications have been made to this ISO.

We will use a Kali disk that has been uploaded to the ISElab ISO datastore for this step in the lab. We will need to modify a few settings associated with the Windows10 VM in vSphere, and will need to follow specific steps in order to successfully boot the live image, **so please follow the following steps carefully.**

1. First, go to your VM “cpre2310-[Net Id]-win10” and click on the “Hardware” tab. Then click “Add” and add a new CD/DVD Drive



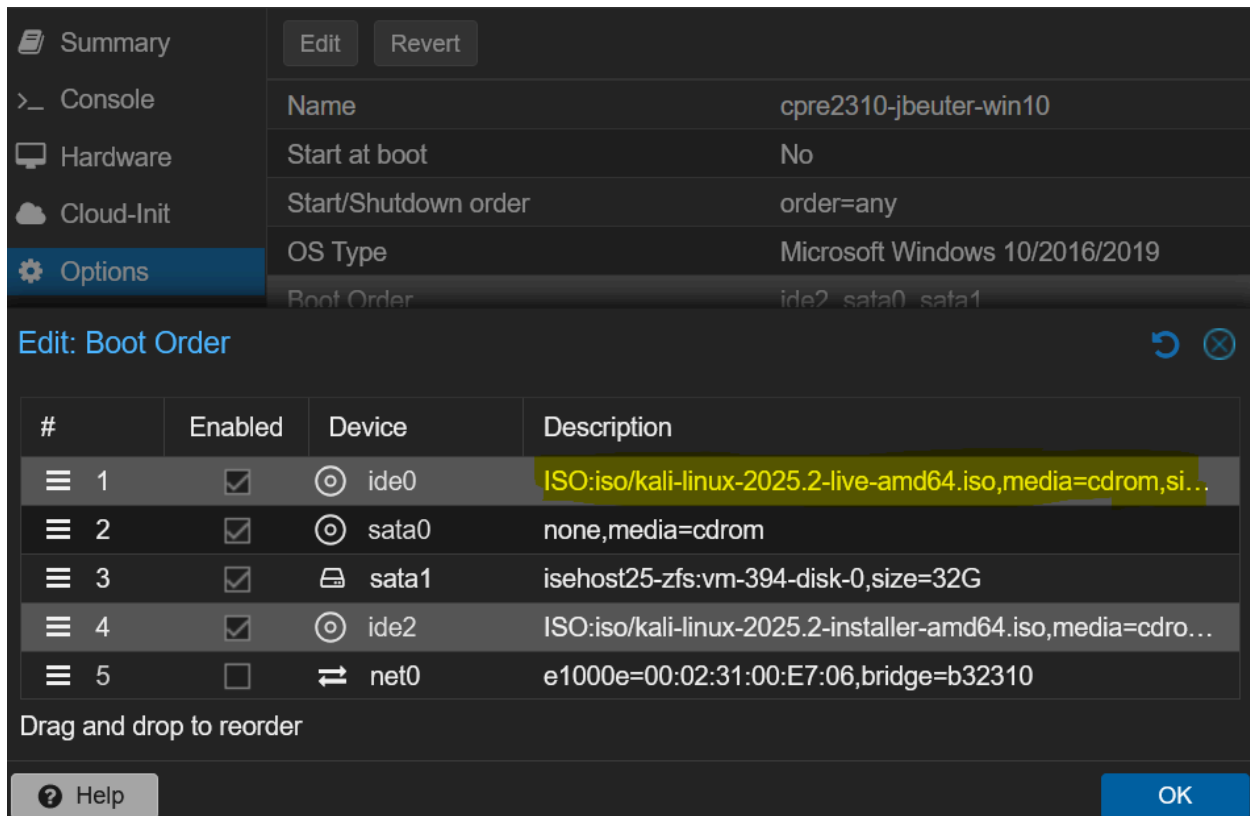
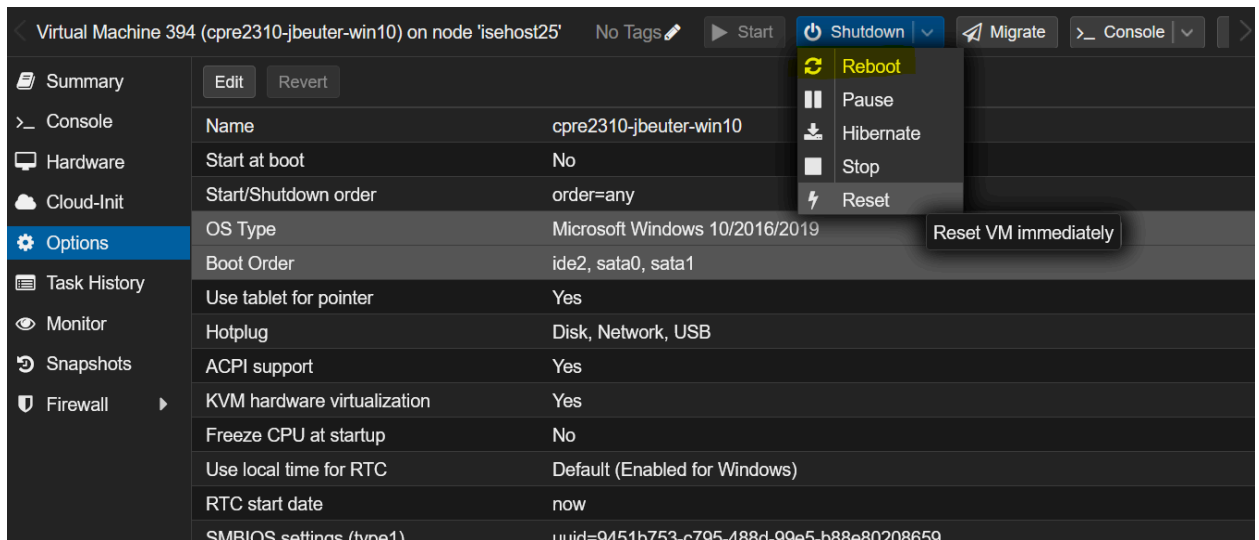
2. In the popup window, expand the CD/DVD drive options and select kali-linux from the ISO image option



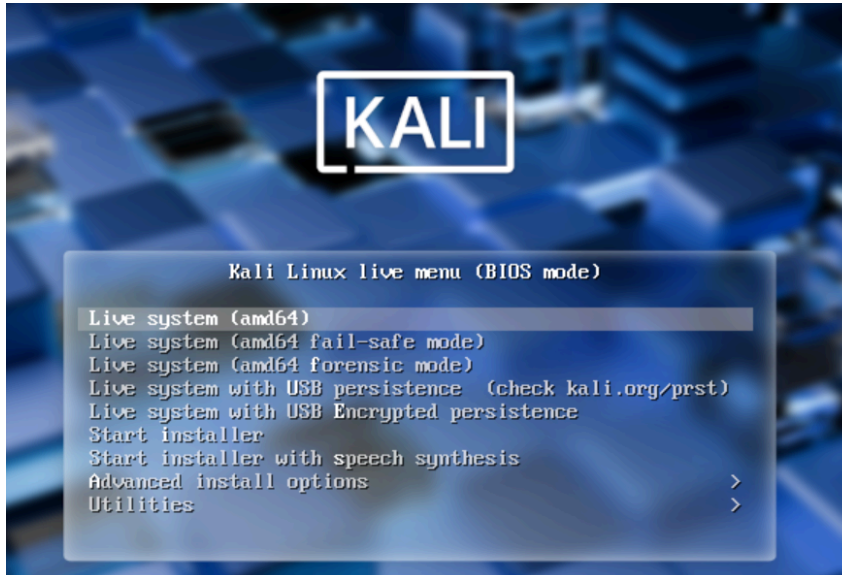
3. Once done, click on the “Add”.



4. Select options and edit the boot order. Place the live kali-linux image as the first option in the boot order, as shown below.
5. To boot from the live image, launch a Remote Console session, and from the start menu, **reboot (not Shutdown/PowerOn)** your win10 machine.



- You should then be presented with a Kali Grub screen. Select “Live system (amd64)” from the listed options. This should boot you into a live Kali system.



- Once the computer is done booting up you should be presented with a Kali instance. Open a terminal and run the command `sudo su` to drop into a root shell
- Run the `lsblk` command to see a list of available block devices (disks/hard drives). **In your lab report compare block storage, file storage, and object storage. Be sure to include when each type of storage should be used.** As you can see, in addition to the loopback device (loop0) and CD drive of sr0 (where our current live system is being run from), we have an entire disk (sda) that is not being used by the operating system. This is our targeted Windows system.

```
(root@kali)-[/home/kali]
# lsblk
NAME        MAJ:MIN RM  SIZE RO TYPE  MOUNTPOINTS
loop0       7:0      0   3.3G  1 loop  /usr/lib/live/mount/rootfs/filesystem.squashfs
            /run/live/rootfs/filesystem.squashfs
sda          8:0      0   32G   0 disk
├─sda1       8:1      0    500M  0 part
└─sda2       8:2      0  31.5G  0 part
sr0         11:0     1    3.8G  0 rom   /usr/lib/live/mount/medium
            /run/live/medium
```

- sda1 holds the windows bootloader, while sda2 contains the NFS filesystem we are interested in accessing. Mount the sda2 partition to /mnt via the following command. **In your lab report explain what the -o, rw, and uid are for in this command.**
`mount -t ntfs-3g -o rw,uid=1000 /dev/sda2 /mnt`

```
(root@kali)-[/mnt]
# ls
'$Recycle.Bin'  pagefile.sys  'Program Files'  swapfile.sys  Windows
bootmgr        PerfLogs      'Program Files (x86)' 'System Volume Information'
BOOTNXT        ProgramData   Recovery         Users
```

10. Because we have access to the root account, and the Windows disk has been mounted to our system, we can now freely access and modify files that we normally would not have access to. The particular file we are interested in is the Windows SAM file, where system passwords are stored. Navigate to the directory containing the SAM file:

```
cd /mnt/Windows/System32/config
```

11. **In your lab report make a comparison of the Security Account Manager (SAM) file to /etc/shadow. Include information about the locations, the information that is stored in each file, who has access to the files, and the format the data is stored in.**

12. We will use the `chntpw` command to remove the Administrator's password. First, to see the available accounts, use the `-l` flag.

```
chntpw -l SAM
```

```
(root@kali)-[/mnt/Windows/System32/config]
# chntpw -l SAM
chntpw version 1.00 140201, (c) Petter N Hagen
Hive <SAM> name (from header): <\SystemRoot\System32\Config\SAM>
ROOT KEY at offset: 0x001020 * Subkey indexing type is: 686c <lh>
File size 65536 [10000] bytes, containing 7 pages (+ 1 headerpage)
Used for data: 355/32120 blocks/bytes, unused: 16/8616 blocks/bytes.
```

RID	Username	Admin?	Lock?
01f4	Administrator	ADMIN	
03ef	Alex		
01f7	DefaultAccount		dis/lock
03e8	defaultuser0		dis/lock
01f5	Guest		
03ec	James		
03ed	Lilly		
03ee	Seregil		
03e9	yellowsnow	ADMIN	

13. We could choose to either create a new account, grant administrative privileges to an existing account, or remove the password to an administrative account. For this example, we will remove the password associated with the “yellowsnow” account. Run the following command:

```
chntpw -u yellowsnow SAM
```

```
- - - - User Edit Menu:
1 - Clear (blank) user password
(2 - Unlock and enable user account) [seems unlocked already]
3 - Promote user (make user an administrator)
4 - Add user to a group
5 - Remove user from a group
q - Quit editing user, back to user select
Select: [q] > █
```

14. Enter “1” for cleaning a user’s password

```
Select: [q] > 1
Password cleared!
===== USER EDIT =====

RID      : 1001 [03e9]
Username: yellowsnow
fullname:
comment :
homedir  :

00000220 = Administrators (which has 2 members)

Account bits: 0x0214 =
[ ] Disabled           | [ ] Homedir req.       | [X] Passwd not req.    |
[ ] Temp. duplicate    | [X] Normal account     | [ ] NMS account       |
[ ] Domain trust ac    | [ ] Wks trust act.     | [ ] Srv trust act     |
[X] Pwd don't expir    | [ ] Auto lockout       | [ ] (unknown 0x08)    |
[ ] (unknown 0x10)     | [ ] (unknown 0x20)     | [ ] (unknown 0x40)    |
```

15. After you have blanked the user’s account, quit from the interactive prompt with “q”, and confirm the write action to the SAM file.

```
Select: [q] > q

Hives that have changed:
#  Name
0  <SAM>
Write hive files? (y/n) [n] : y
0  <SAM> - OK
```

16. Rerun “chntpw -l SAM” and take a screenshot of the “Blank password” field to include in your lab submission. (It should display that the password is blank.)
17. What if you would have found the hash aad3b435b51404eeaad3b435b51404ee in the LM hash portion of your file? What does it mean? Especially, if there are multiple instances of that same hash value.
18. Return to your home directory via the cd command (cd ~) and unmount the windows partition.

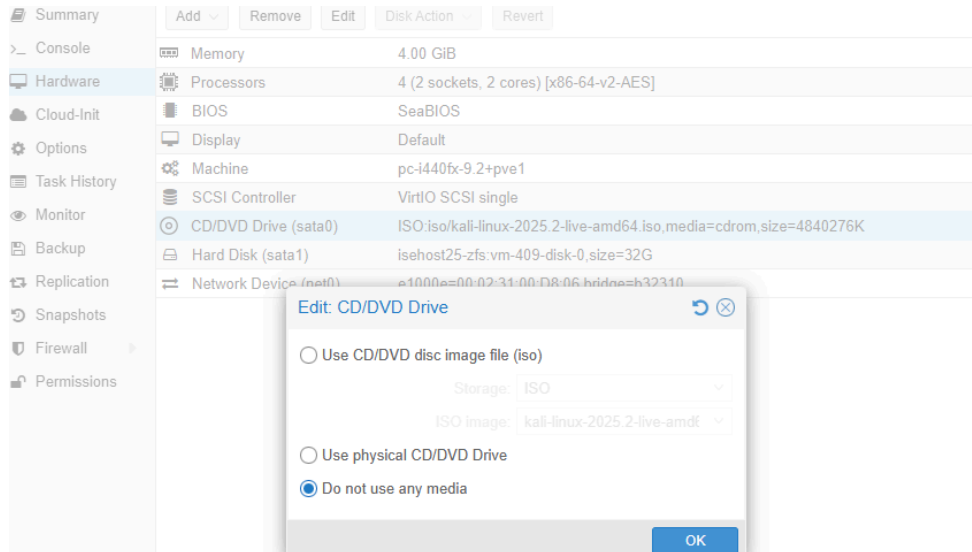
```
(root@kali)-[/mnt/Windows/System32/config]
# cd

(root@kali)-[~]
# umount /mnt
```

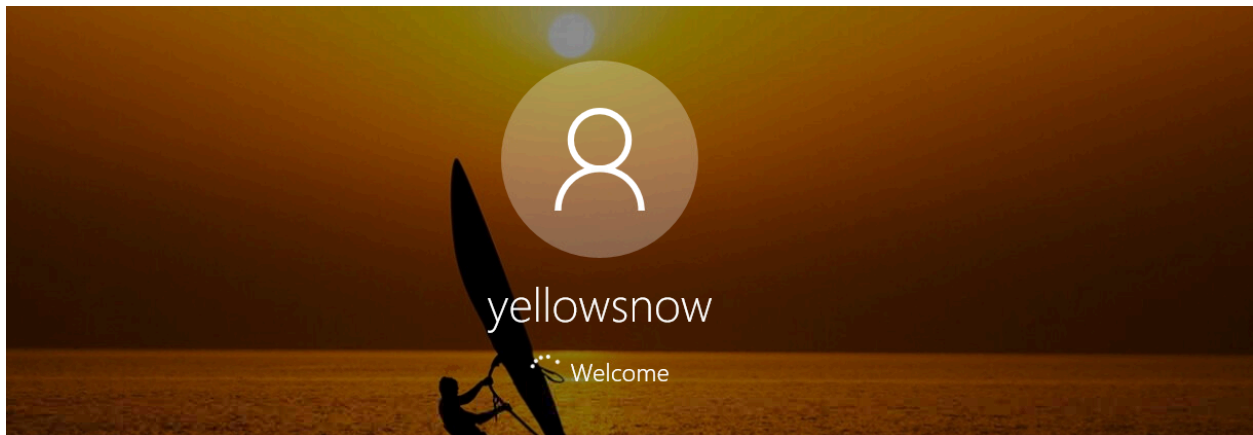
19. Shutdown the live boot of kali using the command `shutdown -h now`


```
(root@kali)-[/home/kali]
# shutdown -h now
```

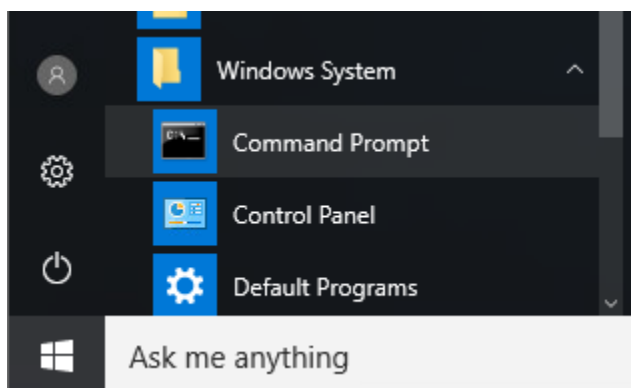
20. Click on the “Hardware” tab then click “Edit.” Remove the CD from the VM.



21. Start your Windows 10 machine. You should be greeted with the Windows login page. Click on the account “yellowsnow”, and it should automatically log you in as yellowsnow to the Windows 10 machine. DO NOT Change any network settings (Select NO).



22. Open a CMD prompt by navigating to “Start -> Windows System -> Command Prompt”.



23. Take a screenshot running the following command to prove that you've successfully logged in as the yellowsnow user:

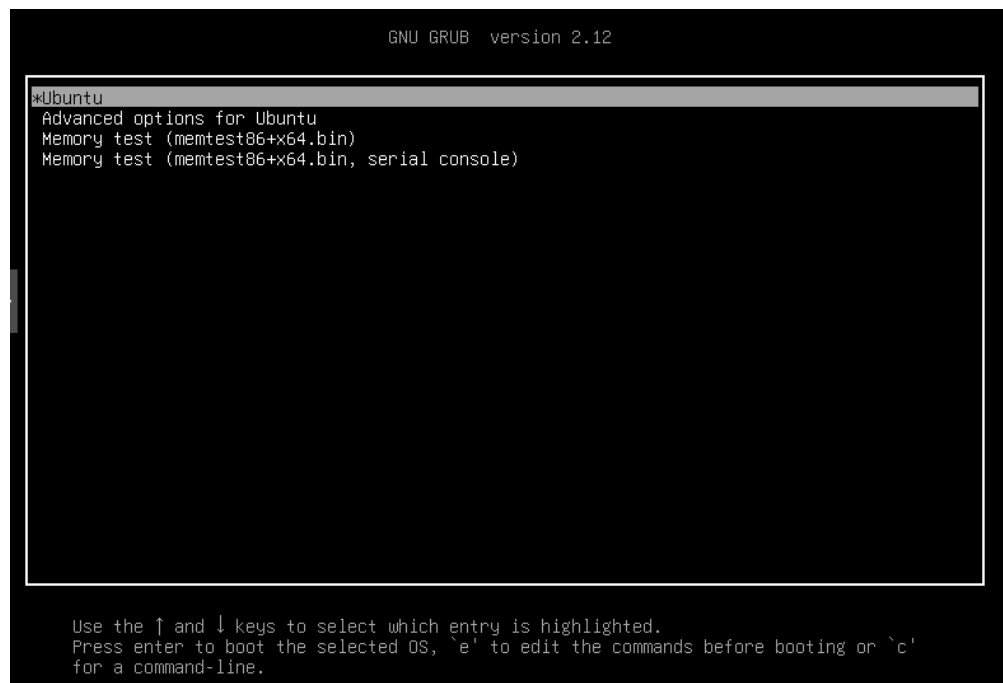
```
echo %USERNAME%
```

Single-user Mode

Single-user mode is a feature included on many Linux systems that allow for a system to be booted into by an administrator for system-wide maintenance with all other accounts disabled to provide concurrency throughout the maintenance. Since the administrative account used in single-user mode is root without a username or password, it can allow access to a system in much the same way as a live image (external media isn't even required). Single-user mode can be disabled via a GRUB password; however, that is not common.

We will now start your Ubuntu 24.04.X Desktop in single-user mode to illustrate how such an undertaking is undertaken.

1. Reboot your Ubuntu desktop.
2. The system will display the boot menu for 5 seconds.



- While the default "Ubuntu" entry is highlighted, press the "e" key on your keyboard to drop into an interactive editor. We will edit the "linux" line, tacking on the word "single" at the end of the line.

```
GNU GRUB version 2.12

setparams 'Ubuntu'

    recordfail
    load_video
    gfxmode $linux_gfx_mode
    insmod gzio
    if [ x$grub_platform = xxen ]; then insmod xzio; insmod lzopio; fi
    insmod part_gpt
    insmod ext2
    set root='hd0,gpt3'
    if [ x$feature_platform_search_hint = xy ]; then
        search --no-floppy --fs-uuid --set=root --hint-bios=hd0,gpt3 --hint-efi=hd0,gpt3 --\
-hint-baremetal=ahci0,gpt3 86b96ab0-66ef-4d42-9f17-3bc57c49c400
    else
        search --no-floppy --fs-uuid --set=root 86b96ab0-66ef-4d42-9f17-3bc57c49c400
    fi
    linux      /boot/vmlinuz-6.8.0-83-generic root=UUID=86b96ab0-66ef-4d42-9f17-3bc57c\
49c400 ro quiet splash ipv6.disable=1 $vt_handoff single
    initrd    /boot/initrd.img-6.8.0-83-generic
```

- After adding the additional line, press F10 on the keyboard to continue booting. You should be presented with the following message. Press "Enter" to be dropped into a root shell.

```
[ OK ] Reached target Rescue Mode.
Starting Update UTMP about System Runlevel Changes...
[ OK ] Finished Update UTMP about System Runlevel Changes.
You are in rescue mode. After logging in, type "journalctl -xb" to view
system logs, "systemctl reboot" to reboot, "systemctl default" or "exit"
to boot into default mode.
Press Enter for maintenance
(or press Control-D to continue):
root@desktop:~# _
```

- Take a screenshot of the following command to verify that you are in single-user mode (should return `N 1`):

```
runlevel
```

We have talked in past labs about reading and writing files once you have root access. But, what about changing commands so they don't run the Ubuntu read command, but they run "Alexs_evil_read_command" which reads all the data and lets the system operate as it should

but has the BONUS FEATURE of writing everything it reads to a file called Alexs_gathered_information or over a network connection.

If you are interested in writing a hook like this, there is a nice article on hooking system calls in the kernel...<https://ritcsec.wordpress.com/2020/11/22/linux-syscall-hooking/>

6. **Pick two of the following controls:Secure Boot, BitLocker (Windows), LUKS (Linux full-disk encryption), making USB ports non-bootable / disabling external-boot in firmware.** For each you choose briefly describe how it works (1–2 sentences) and how it would prevent or reduce the risk demonstrated in today’s lab (single-user mode, booting a live OS from a removable media, or reading the disk offline.)

Lab Template

1. **Fill in the following table. Be sure to include at least 2 sentences describing each storage system. Also, include when each type of storage should be used and whether or not it was used/accessed/showcased in the lab.**

(10 points)

Name	Description	Usecase
Block		
Object		
File		

2. **Explain what the -o, rw, and uid are for in the following command**

```
mount -t ntfs-3g -o rw,uid=1000 /dev/sda2 /mnt
```

(10 points)

3. **How is the Security Account Manager (SAM) file similar to/different from /etc/shadow? Include information about the locations of the file, information that is stored in each, who has access to the files, and the format the data is stored in.**

(20 points)

4. **Rerun “chntpw -l SAM” and take a screenshot of the “Blank password” field to include in your lab submission**

(10 points)

5. What if you would have found the hash `aad3b435b51404eeaad3b435b51404ee` in the LM hash portion of your file? What does it mean? Especially, if there are multiple instances of that same hash value.

(10 points)

6. Take a screenshot running the following command to prove that you've successfully logged in as the yellowsnow user:

```
echo %USERNAME%
```

(10 points)

7. Take a screenshot of the following command to verify that you are in single-user mode (should return `N 1`):

```
runlevel
```

(10 points)

8. Pick two of the following controls: Secure Boot, BitLocker (Windows), LUKS (Linux full-disk encryption), making USB ports non-bootable / disabling external-boot in firmware. Describe how each works (1–2 sentences) and how it would prevent or reduce the risk demonstrated in today's lab.

(20 points)